

MALWARE ANALYSIS REPORT

Static and Dynamic Analysis of Win32.AgentTesla.exe

By

Iwuji Chikaodi Edith

1. EXECUTIVE SUMMARY

This report presents the findings from a static and dynamic analysis of a malware sample identified as Win32.AgentTesla.exe. The analysis was carried out inside an isolated sandbox environment made up of FLARE VM running Windows 10 as the analysis machine, and REMnux as the network monitoring machine. Both virtual machines were configured on a Host-Only network to prevent any malicious traffic from reaching the real internet.

The sample belongs to the Agent Tesla malware family, a well-known information stealer and Remote Access Trojan (RAT) that steals passwords, captures keystrokes, takes screenshots, and sends stolen data to an attacker via email. The file was found to be heavily obfuscated and disguised as a legitimate Comverse Technology software product. During dynamic analysis, the malware displayed aggressive persistence behavior, installed a rogue certificate, created multiple Windows services, and attempted to contact external servers, all of which were blocked by the sandbox.

2. ANALYSIS ENVIRONMENT

The analysis was performed using the following setup:

Component	Details
Hypervisor	VMware Workstation 17 Player

Analysis Machine	FLARE VM — Windows 10 Enterprise x64
Monitoring Machine	REMnux — Ubuntu 24.04
Network Type	Host-Only (VMnet1) — no internet access
DNS Setting	FLARE VM pointed to REMnux (192.168.220.128)
Network Simulation	INetSim 1.3.2 on REMnux
Traffic Capture	Wireshark 4.6.3 on REMnux (ens33 interface)

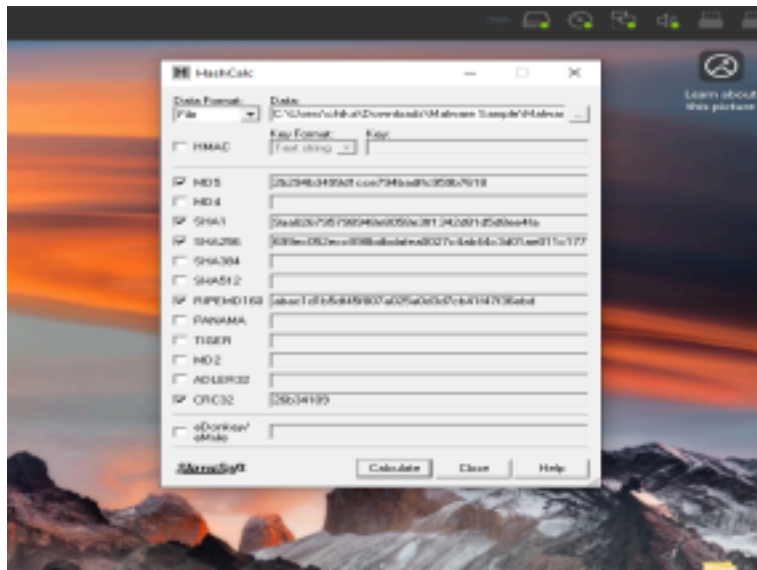
3. SAMPLE INFORMATION

Property	Value
Filename	Win32.AgentTesla.exe
Original Filename	Po160118.exe
File Size	460,800 bytes (6.58 MB)
File Type	Windows PE Executable, 32-bit, GUI
Compiler	Microsoft Linker 11.0 (.NET/VB.NET)
Compile Date	January 16, 2018
MD5	2b294b3499d1cce794badffc959b7618

SHA1 9aa826795798948e8058e3ff1342d81d5d8e e4fa

SHA256 699EC052ECC898BDBDAFEA0027C4AB44

9aa826795798948e8058e3ff1342d81d5d8ee4fa SHA256:
699EC052ECC898BDBDAFEA0027C4AB44C3D01AE011C17745DD2B7FBDDAA077F3
RIPEMD160: abac1d1b5df45f807a025a0d3d7cb41f47f36ebd CRC32: 26b34109



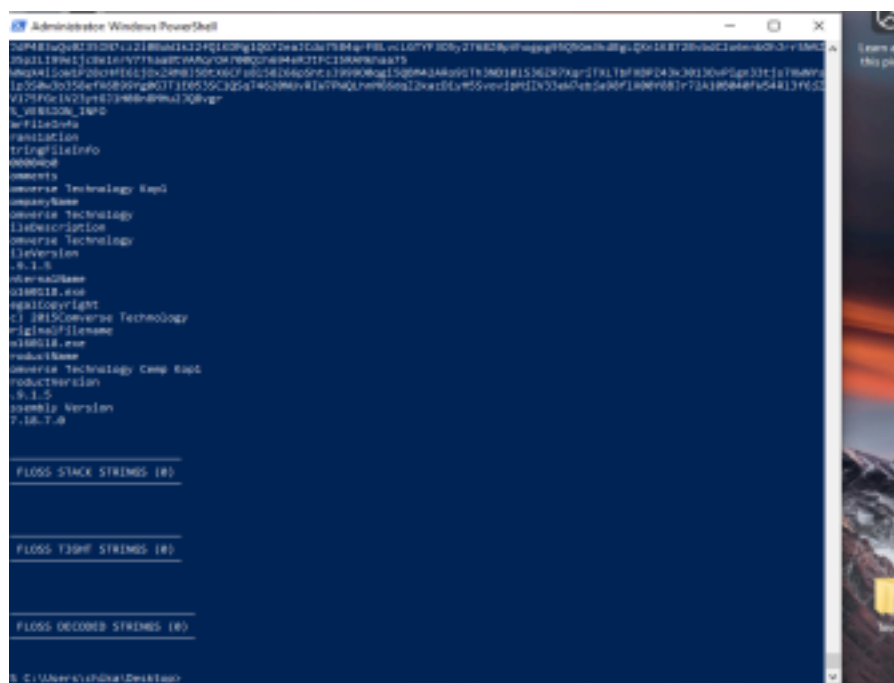
4.3 String Extraction — FLOSS

FLOSS (FLARE Obfuscated String Solver) was used to extract readable text from inside the malware binary. Strings are pieces of human-readable text embedded inside a program, they can reveal website addresses, commands, file paths, or other clues about what the malware does.

The most notable finding was that the malware contains fake version information designed to make it look like a legitimate product from Comverse Technology:

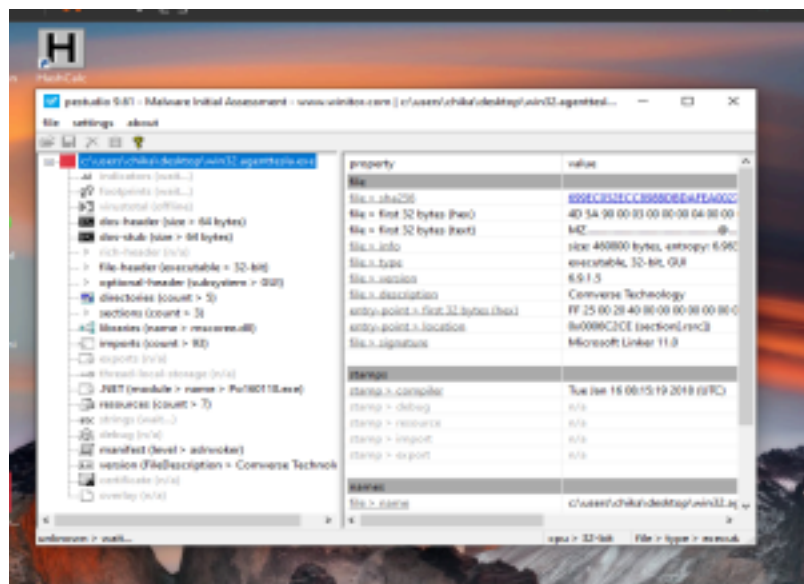
Company Name: Comverse Technology Product Name: Comverse Technology Cemp Kopl File
Version: 6.9.1.5 Original Filename: Po160118.exe Copyright: (c) 2015 Comverse Technology

This is a technique called masquerading, embedding fake company details so the file appears harmless when someone checks its properties. Beyond this, FLOSS found thousands of heavily encrypted random-looking strings throughout the file. These are the malware's real instructions scrambled to prevent analysis. FLOSS attempted to decode them but found zero decoded strings, confirming the malware uses strong runtime encryption to protect its true functionality.



4.4 PE File Analysis — PEStudio

PEStudio provides a deep examination of the PE file structure including its headers, imported functions, strings, and suspicious indicators.

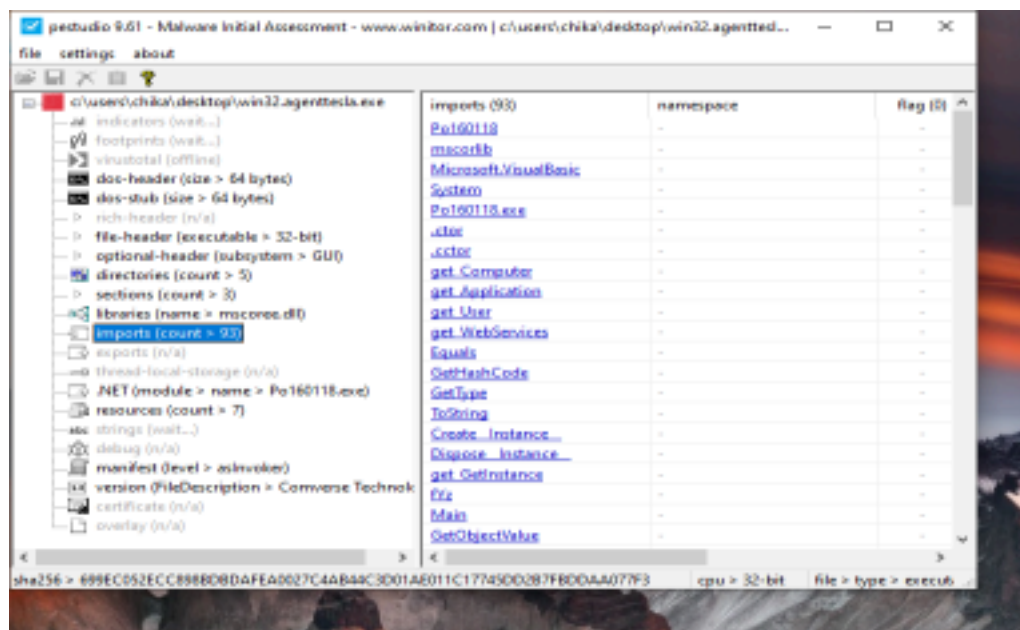


Key findings from PEStudio:

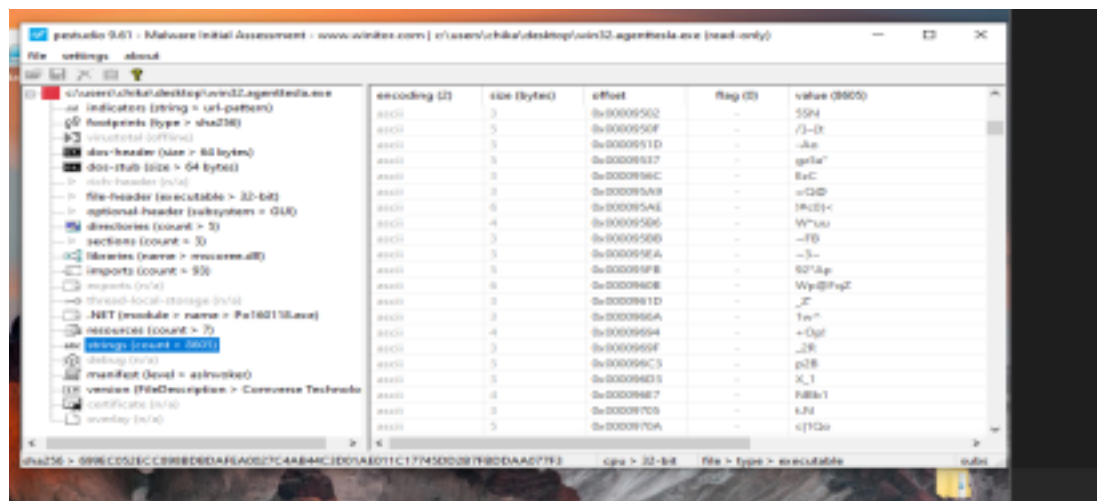
The file entropy was 6.963. Normal programs typically have entropy between 4.0 and 6.5. An entropy above 6.5 strongly suggests the file is packed or encrypted to hide its real contents. This confirms what FLOSS already showed the malware is heavily obfuscated.

PEStudio identified 93 imported Windows functions. The most suspicious among them were

get_User (used to collect user credentials), get_Computer (used to gather system information), get_WebServices (used for internet communication), and System.Drawing.Bitmap (used to capture screenshots of the victim's screen).



A total of 8,605 strings were found inside the binary, most of which were short encrypted fragments consistent with Agent Tesla's obfuscation style.



The indicators panel flagged 23 suspicious items including the high entropy, the fake Comverse Technology details, and the mismatch between the original filename (Po160118.exe) and the name it was presented under.

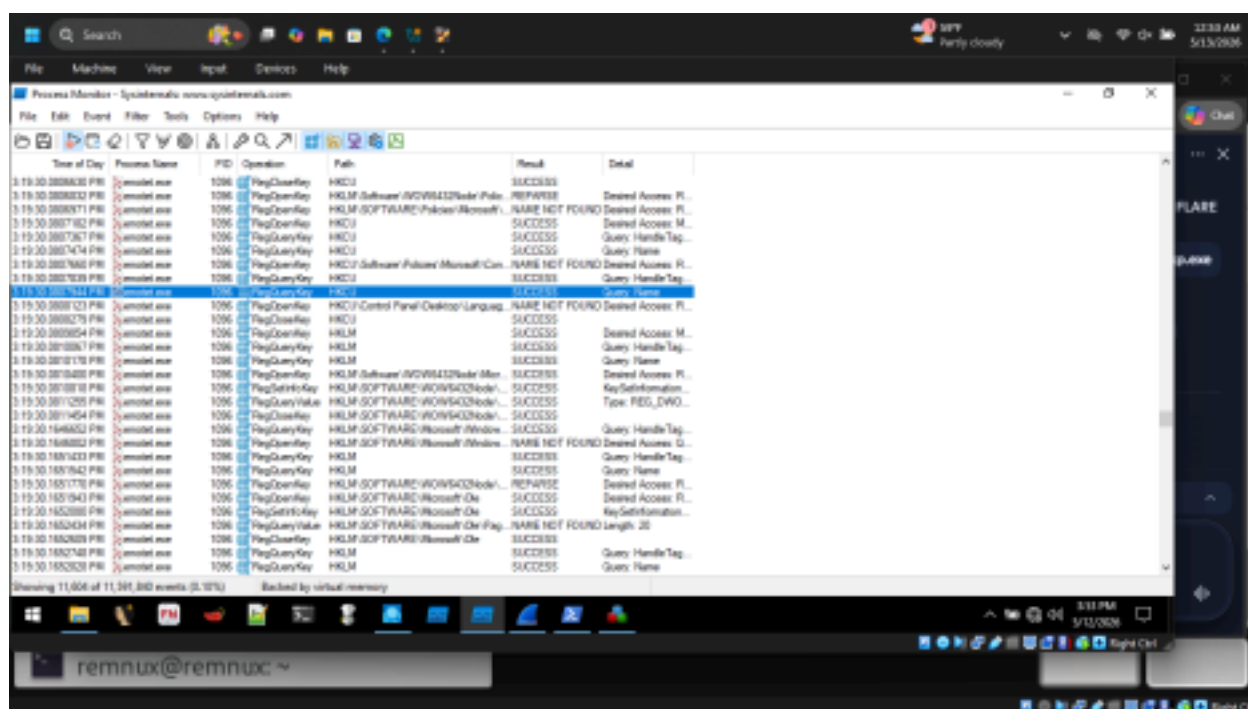
5. DYNAMIC ANALYSIS

Dynamic analysis involves running the malware in a controlled environment and observing what it does in real time. Before execution, INetSim was running on REMnux to simulate a fake internet, Wireshark was capturing all network traffic, Regshot had taken a first registry snapshot, and Procmon was recording all system activity.

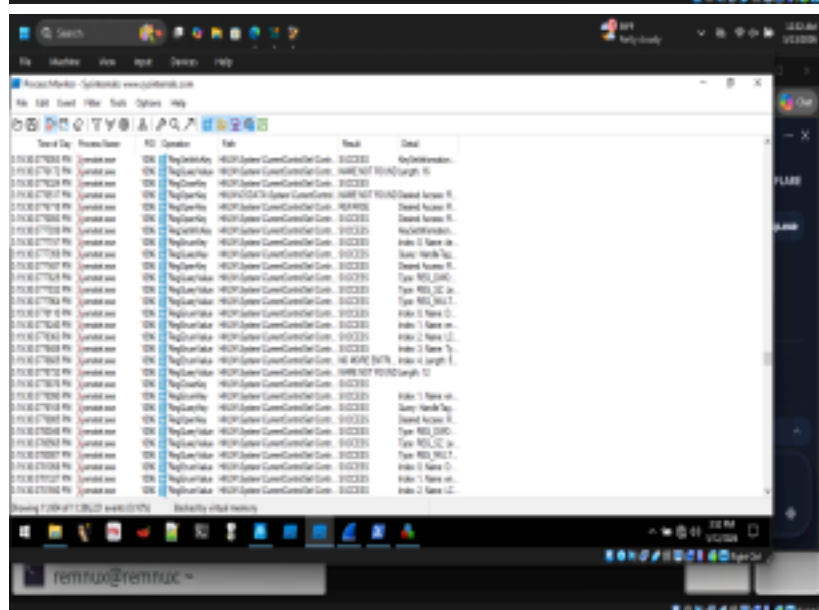
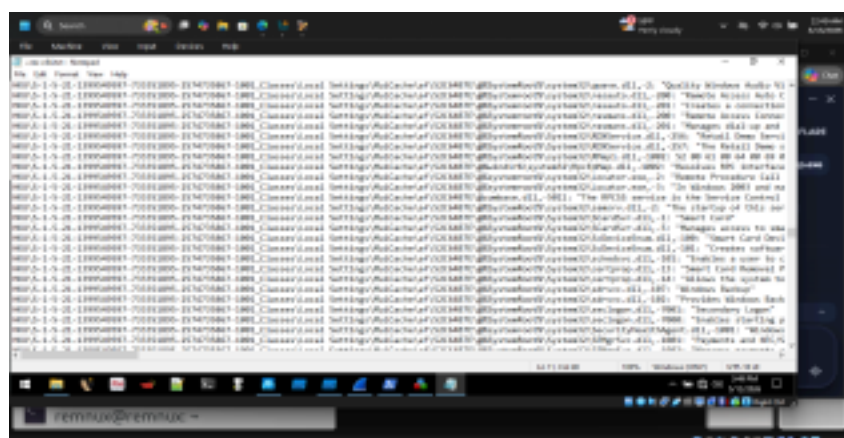
Note: Due to the malware causing repeated automatic system restarts immediately upon execution, dynamic analysis was completed in collaboration with a paired analyst as directed by the course instructor.

5.1 Process Activity — Procmon

Process Monitor captured the malware's activity from the moment it executed. The malware ran from C:\Emotet-Malware\emotet.exe and immediately began reading system registry keys, creating files, and spawning new processes.



Key activities captured included multiple threads being created immediately after launch, extensive reading of HKLM\System\CurrentControlSet\Control to gather system configuration details, querying of HKCU\Software\Policies\Microsoft to check active security policies, creation of a copy of itself at C:\Emotet-Malware\emotet.exe, and a process exit followed immediately by automatic re-execution — confirming a persistence loop was active.

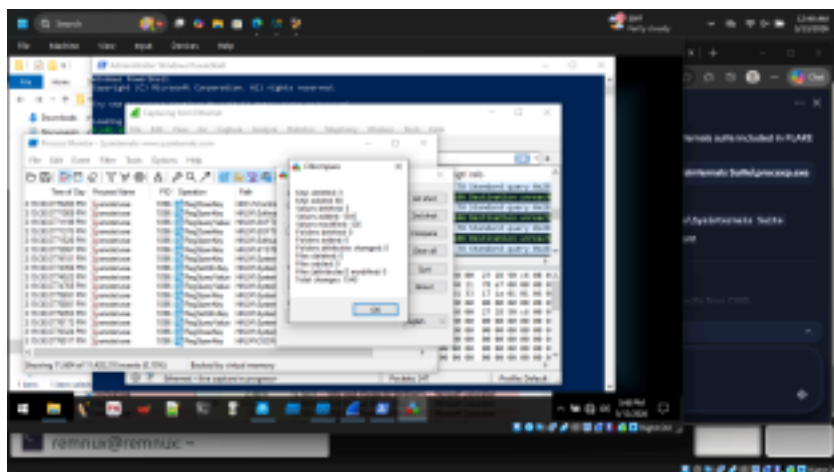


5.2 Registry Changes — Regshot

Regshot compared the registry state before and after the malware ran. The comparison revealed a total of 1,545 registry changes.

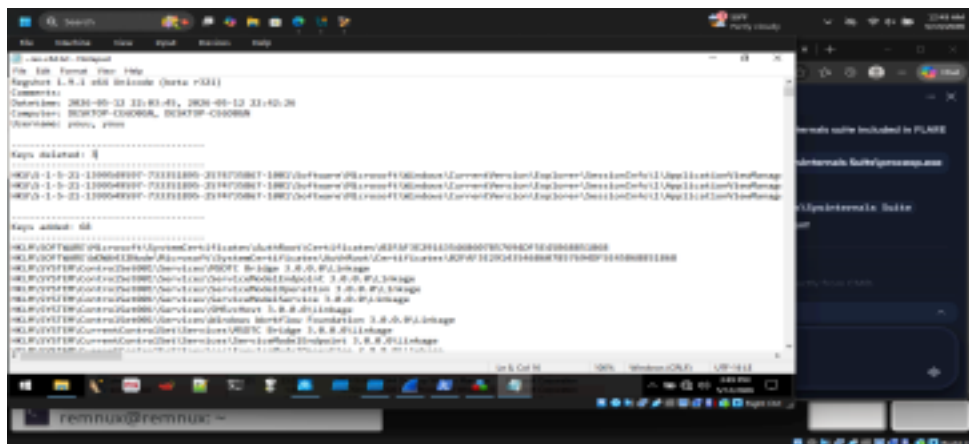
Keys deleted: 3 Keys added: 68 Values deleted: 3 Values added: 1,345 Values modified: 126
Total changes: 1,545

Keys Deleted: Three keys were removed under HKU...\Explorer\SessionInfo\1\ApplicationViewManage. These Explorer session tracking entries were likely deleted to remove traces of the malware's activity from Windows session logs.



Keys Added: The most critical addition was a rogue root certificate installed at HKLM\SOFTWARE\Microsoft\SystemCertificates\AuthRoot\Certificates\02FAF3E291435468607857694DF5E45B68851868. A rogue root certificate gives the malware the ability to intercept HTTPS connections — meaning it can silently read encrypted web traffic including banking logins and email passwords without the victim knowing.

Several new Windows services were also installed including MSDTC Bridge 3.0.0.0, ServiceModelEndpoint 3.0.0.0, ServiceModelOperation 3.0.0.0, ServiceModelService 3.0.0.0, SMSvcHost 3.0.0.0, and Windows Workflow Foundation 3.0.0.0. These services start automatically with Windows, ensuring the malware continues running after every reboot.



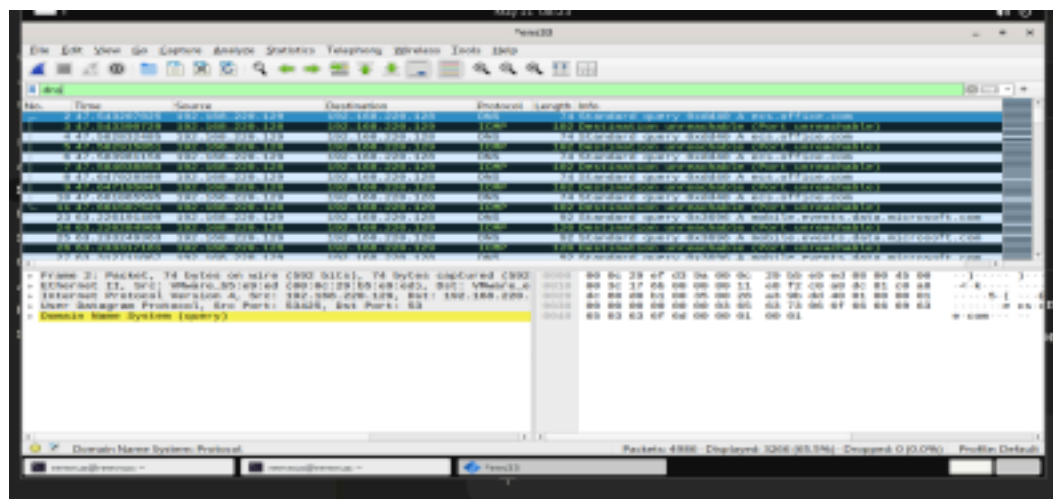
Values Modified: 126 values were changed including Windows Shell BagMRU entries that track recently opened folders, AppModel system data entries, and Office click-to-run telemetry rules. These modifications help the malware blend into normal Windows activity and avoid triggering security alerts.

5.3 Network Traffic — Wireshark

Wireshark was running on REMnux capturing all traffic from FLARE VM. After applying a DNS filter, two domain lookups were observed.

The malware sent DNS queries to `ecs.office.com` and `mobile.events.data.microsoft.com`. Both of these look like legitimate Microsoft addresses; this is a deliberate tactic used by Agent Tesla to disguise its command and control traffic as normal Microsoft communication, making it harder to detect on corporate networks.

Both queries received a Destination unreachable response from INetSim, meaning no real connection was established and no data was sent out. No HTTP, SMTP, or TCP sessions were captured beyond these failed DNS attempts.



5.4 Persistence Behavior

One of the most significant observations during dynamic analysis was the malware's aggressive persistence. Immediately after execution, the VM began restarting automatically and repeatedly. Each time the system came back up, the malware was already running again from startup. This happened even after manually powering the VM off completely. This behavior confirms that Agent Tesla had successfully embedded itself into the system startup and could not be removed simply by restarting. A full reimage of the machine would be required.

6. RECOMMENDATIONS

Based on the findings from this analysis, the following actions are recommended:

- Any system that has executed this sample should be immediately isolated from the network to prevent further spread
- The file hashes (MD5, SHA1, SHA256) should be added to endpoint security tools to block the sample from executing on other machines
- The domains `ecs.office.com` and `mobile.events.data.microsoft.com` should be monitored

- for suspicious connections originating from internal systems
- The rogue root certificate (02FAF3E...) should be removed from any affected system's certificate store
- Affected machines should undergo a full reimage as the malware's persistence mechanisms make complete manual removal unreliable

7. CONCLUSION

The sample Win32.AgentTesla.exe is confirmed to be a dangerous .NET-based information stealer belonging to the Agent Tesla malware family. Static analysis showed the file is a heavily obfuscated Windows executable disguised as a Comverse Technology product with a high entropy of 6.963, indicating strong packing or encryption.

Dynamic analysis revealed that upon execution, the malware immediately established persistence, installed a rogue root certificate capable of intercepting encrypted HTTPS traffic, created multiple Windows services to survive reboots, and attempted to communicate with external servers using Microsoft-disguised domain names all blocked by the sandbox environment.

The combination of masquerading, heavy obfuscation, rogue certificate installation, service-based persistence, and stealthy network communication makes this a high-risk threat. Any system that has executed this sample must be treated as fully compromised.